Universidad Mariano Gálvez de Guatemala
Facultad de Ingeniería en Sistemas de Información y Ciencias de la Computación Dirección de Posgrados
MAESTRÍA EN SEGURIDAD DE LA INFORMACIÓN

Tarea Semana 3

Rediseño seguro de una aplicación aplicando OWASP ASVS

Curso	Seguridad en Aplicaciones
Semana	Semana 3
Modalidad	Individual

Indicador de logro
Rediseña de forma segura un módulo o aplicación inicialmente insegura, aplica principios de diseño seguro y mapea requisitos de OWASP ASVS a decisiones concretas de arquitectura y desarrollo.

1. Propósito de la actividad

Esta actividad utiliza la metodología de caso tipo Harvard. El estudiante deberá analizar una situación empresarial realista, identificar decisiones de diseño inseguras y asumir el rol de Arquitecto de Seguridad de Aplicaciones para proponer un rediseño técnicamente justificable.

El objetivo no es elaborar una lista de vulnerabilidades. Se espera que cada decisión de seguridad pueda relacionarse con el contexto de la aplicación, un principio de desarrollo seguro, un requisito de OWASP ASVS y una forma de verificar que el control funciona.

2. Competencias a desarrollar

- Analizar el perfil de riesgo y criticidad de una aplicación.
- Diferenciar una corrección puntual de vulnerabilidades de un rediseño seguro.
- Aplicar principios de diseño seguro a decisiones de arquitectura.
- Utilizar OWASP ASVS como fuente de requisitos verificables de seguridad.
- Justificar controles técnicos considerando riesgo, impacto y viabilidad.
- Comunicar decisiones de seguridad a audiencias técnicas y de negocio.

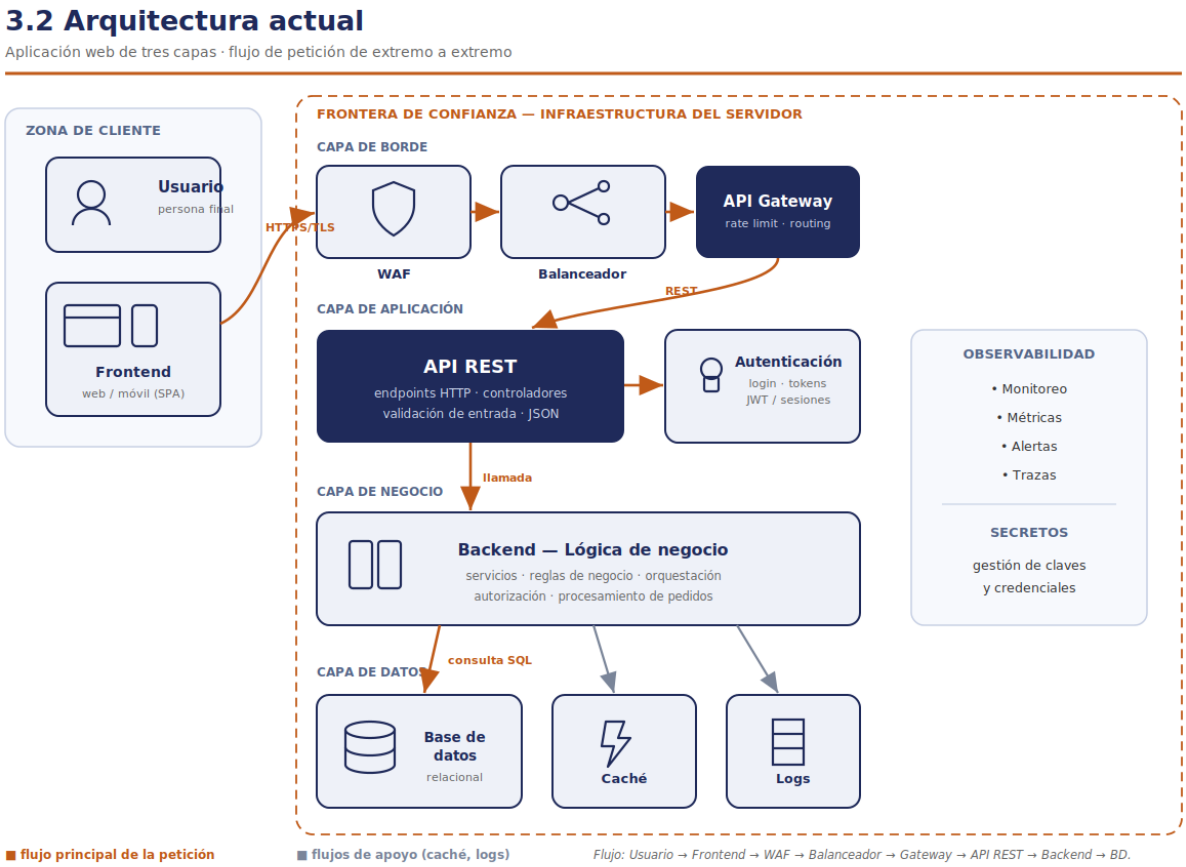
3. Caso de estudio: FinanciaWeb

FinanciaWeb es una aplicación web desarrollada por una empresa de servicios financieros. Su objetivo es permitir que los clientes administren operaciones básicas desde Internet. El sistema fue construido bajo presión de tiempo y varios controles de seguridad se pospusieron para una fase posterior.

3.1 Funcionalidades actuales

- Inicio de sesión con usuario y contraseña.
- Consulta de información personal y saldos.
- Registro de cuentas de terceros.
- Realización de transferencias.
- Descarga de estados de cuenta en PDF.
- Modificación de correo electrónico y número telefónico.
- Recuperación de contraseña.
- Consumo de servicios mediante una API REST.

3.2 Arquitectura actual (General)



3.3 Decisiones y condiciones actuales

- Frontend y backend se encuentran desplegados en el mismo servidor.
- La API puede ser consumida directamente desde Internet.
- La aplicación utiliza únicamente usuario y contraseña.
- Las contraseñas se almacenan utilizando SHA-256.
- Una misma sesión puede permanecer abierta indefinidamente mientras el navegador continúe abierto.
- Los permisos de los usuarios se validan principalmente desde el frontend.
- Los identificadores de cuentas se envían directamente en las URL.
- Los mensajes de error muestran información técnica del servidor.
- El sistema registra únicamente los inicios de sesión.
- Los archivos PDF generados quedan temporalmente disponibles mediante una URL.
- El backend utiliza una única cuenta de base de datos con permisos de lectura, escritura y administración.
- No existe documentación formal de requisitos de seguridad.
- No se ha realizado modelado de amenazas.
- No existe una clasificación formal de datos.

3.4 Resultados de una revisión de seguridad

1. Un usuario logró modificar un identificador en una URL y visualizar información perteneciente a otro cliente.
2. Se detectaron múltiples intentos automatizados de inicio de sesión.
3. Los tokens de sesión continúan siendo válidos después de cambiar la contraseña.
4. Algunos errores de la API muestran nombres de tablas y componentes internos.
5. Es posible enviar valores inesperados directamente contra determinados endpoints.
6. Los administradores utilizan el mismo mecanismo de autenticación que los usuarios normales.
7. Algunos endpoints solamente verifican permisos desde la interfaz web.
8. Los estados de cuenta descargados contienen información financiera sensible.
9. No se registra quién modifica información crítica de un cliente.
10. El equipo de desarrollo no tiene criterios claros para decidir qué controles de seguridad debe implementar.

4. Actividades que debe desarrollar

Parte 1. Perfil de seguridad de la aplicación

Construya un Perfil de Seguridad de FinanciaWeb antes de proponer controles. El perfil debe permitir comprender qué se protege, de quién se protege, qué impacto tendría una falla y qué nivel de aseguramiento requiere. Tomando como referencia la siguiente tabla:

Elemento	Análisis esperado
Tipo de aplicación	Web, API, móvil, interna u otras categorías aplicables.
Usuarios	Clientes, administradores, operadores, sistemas y servicios.
Información procesada	Datos personales, financieros, credenciales, documentos u otros.
Operaciones críticas	Transferencias, cambios de datos, recuperación de contraseña, administración, etc.

Exposición	Internet, redes internas, terceros, API u otros canales.
Impacto	Consecuencias sobre confidencialidad, integridad y disponibilidad.
Criticidad	Baja, media, alta o crítica, con justificación.
Nivel ASVS propuesto	Nivel 1, 2 o 3, acompañado de una justificación basada en el contexto.

El nivel ASVS seleccionado debe justificarse. No se calificará únicamente indicar un nivel sin explicar por qué corresponde al riesgo y a la naturaleza de la aplicación.

Parte 2. Identificación de problemas de diseño

Identifique al menos ocho problemas de seguridad presentes en la arquitectura actual, tomando de referencia los problemas identificados en la auditoría de seguridad que se menciona anteriormente. No se limite a escribir el nombre de una vulnerabilidad: explique por qué la decisión de diseño es insegura.

Problema identificado	Riesgo	Posible impacto	Componente afectado

Parte 3. Rediseño seguro de la aplicación

Diseñe nuevamente la arquitectura de FinanciaWeb. Debe presentar un diagrama de la arquitectura actual y un diagrama de la arquitectura propuesta. Puede agregar componentes tales como gestión de identidad, controles de API, segmentación, servicios de auditoría, gestión de secretos u otros; sin embargo, cada componente deberá responder a un riesgo identificado.

Criterio importante
No se calificará por la cantidad de componentes agregados. Se calificará la relación entre riesgo, decisión de diseño, principio de seguridad, requisito ASVS y mecanismo de verificación.

Parte 4. Principios de desarrollo seguro

Seleccione y aplique al menos cinco principios de diseño seguro. Entre otros, puede considerar: mínimo privilegio, defensa en profundidad, Fallo Seguro, separación de responsabilidades, minimización de superficie de ataque, validación de entradas, protección de datos por diseño, registro y trazabilidad, y gestión segura de secretos, aceptabilidad psicológica.

Principio	Problema actual	Decisión de diseño propuesta	Beneficio
Mínimo privilegio	El backend utiliza una cuenta de BD con privilegios administrativos.	Crear cuentas de servicio con permisos estrictamente necesarios.	Reduce el impacto de un compromiso.

Parte 5. Aplicación de OWASP ASVS

Seleccione un mínimo de ocho requisitos de OWASP ASVS provenientes de al menos cinco áreas o categorías diferentes. Deberá consultar la versión vigente indicada por el docente, localizar el identificador exacto del requisito y demostrar cómo dicho requisito modifica el diseño de FinanciaWeb.

Categoría ASVS	Requisito / ID	Problema encontrado	Decisión de diseño	Cómo se verificará

La lógica esperada es: Requisito ASVS → problema → decisión de arquitectura/desarrollo → mecanismo de verificación.

Parte 6. Cinco decisiones críticas de arquitectura

Seleccione las cinco decisiones de diseño que considere más importantes para proteger FinanciaWeb. Para cada una, responda:

- ¿Qué problema resuelve?
- ¿Qué principio de diseño seguro aplica?
- ¿Qué requisito ASVS respalda la decisión?
- ¿Dónde debe implementarse?
- ¿Cómo demostraría que funciona?

Parte 7. Escenario de ataque: antes y después

Seleccione uno de los siguientes escenarios y analice su evolución antes y después del rediseño:

- Robo de credenciales.
- Acceso a la cuenta de otro cliente.
- Manipulación de una transferencia.
- Ataque contra la API.
- Robo de una sesión.
- Compromiso de una cuenta administrativa.

En la sección “Antes del rediseño”, describa cómo podría progresar el ataque utilizando las debilidades actuales. En la sección “Después del rediseño”, identifique los controles que impedirían, detectarían o limitarían cada etapa. La finalidad es demostrar defensa en profundidad.

Parte 8. Decisión ejecutiva

Analice la siguiente afirmación del gerente del proyecto:

> *“Implementar todos estos controles aumentará el tiempo de desarrollo. La aplicación ya funciona y solamente necesitamos corregir las vulnerabilidades encontradas.”*

Redacte una respuesta ejecutiva de máximo 300 palabras en la que explique por qué corregir únicamente vulnerabilidades puede ser insuficiente, qué riesgos permanecerían, qué aporta OWASP ASVS y qué controles deberían considerarse condiciones obligatorias antes de publicar la nueva versión.

5. Entregable

Entregue un único documento de 6 a 10 páginas que incluya, como mínimo:

1. Portada.
2. Perfil de seguridad de FinanciaWeb.
3. Identificación de al menos ocho problemas de diseño.
4. Diagrama de arquitectura actual.
5. Diagrama de arquitectura segura propuesta.
6. Aplicación de al menos cinco principios de diseño seguro.
7. Matriz de al menos ocho requisitos ASVS pertenecientes a cinco áreas diferentes.

8. Cinco decisiones críticas de arquitectura.
9. Análisis de un escenario de ataque antes y después del rediseño.
10. Conclusión o respuesta ejecutiva.
11. Referencias utilizadas.

6. Requisitos de presentación

- Formato: PDF o Word, según indique el docente.
- Extensión sugerida: 6 a 10 páginas, sin contar portada y referencias.
- Los diagramas pueden elaborarse con la herramienta de preferencia del estudiante.
- Las decisiones deben estar justificadas; no se aceptarán respuestas formadas únicamente por listas de controles.
- Todo requisito de OWASP ASVS utilizado debe incluir su identificador y una explicación aplicada al caso.
- Cuando se utilicen fuentes externas, deberán citarse de forma adecuada.

7. Rúbrica de evaluación

Criterio	Excelente	Aceptable	Insuficiente
Perfil de seguridad y criticidad	Perfil completo, coherente y correctamente justificado.	Perfil suficiente, con justificación parcial.	Perfil incompleto o sin relación clara con el riesgo.
Análisis de problemas de diseño	Identifica y explica causas, riesgos e impactos con precisión.	Identifica problemas relevantes, pero con análisis limitado.	Enumera vulnerabilidades sin explicar decisiones de diseño.
Rediseño de arquitectura	El diseño propuesto responde directamente a los riesgos y demuestra defensa en profundidad.	El diseño mejora la seguridad, aunque algunas decisiones carecen de justificación.	Se agregan componentes sin relación clara con los riesgos.
Principios de desarrollo seguro	Aplica cinco o más principios correctamente y los vincula con decisiones concretas.	Aplica los principios de forma general.	Menciona principios sin demostrar su aplicación.
Uso de OWASP ASVS	Mapea 8 o más requisitos, de 5 o más áreas, con IDs correctos y decisiones verificables.	Cumple la cantidad mínima con explicación parcial.	Requisitos incompletos, sin IDs o copiados sin aplicación al caso.
Escenario antes/después	Demuestra claramente cómo el rediseño previene, detecta o limita el ataque.	Presenta comparación general con algunos controles.	No demuestra el efecto del rediseño.
Argumentación y decisión ejecutiva	Justificación técnica y de negocio clara, concisa y convincente.	Argumentación suficiente, aunque superficial.	Conclusiones sin respaldo técnico.

Presentación y claridad	Documento profesional, ordenado, legible y correctamente referenciado.	Documento comprensible con detalles de forma por mejorar.	Documento desorganizado o difícil de interpretar.